

Cyber Threat Intelligence

Executive Briefing

Report Date: June 29, 2026

Generated: 2026-06-29 10:26 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	7	8	1	16

2. Executive Summary

This briefing details the security posture for June 29, 2026, following an analysis of 16 identified vulnerabilities: 0 Critical, 7 High, 8 Medium, and 1 Low. The current organizational risk posture remains elevated, characterized by a CVSS v3.1 rating of High due to the prevalence of systemic exploitation vectors in our primary package management infrastructure. CVE-2026-55698, identified as Insecure Lockfile Execution in pnpm, represents our most significant threat due to its capacity to bypass standard integrity validation controls during the build lifecycle. Immediate remediation and the implementation of restrictive configuration controls are mandatory to mitigate potential unauthorized arbitrary code execution across our development environments.

3. Critical Action List

1. Immediately patch pnpm to the latest secure version to remediate CVE-2026-55698 within 24 hours.
2. Restrict Gonic playlist creation privileges and apply filesystem-level access controls to mitigate CVE-2026-49340 within 48 hours.
3. Update pnpm engine selection configurations to prevent unauthorized paquet native installs (CVE-2026-55697) within 72 hours.
4. Implement strict manifest validation protocols to neutralize lifecycle script spoofing (CVE-2026-55487) within 72 hours.
5. Apply path sanitization patches to the pnpm stage download process (CVE-2026-55700) within 72 hours.
6. Review and audit all downstream dependencies affected by current pnpm high-severity findings by end-of-week.
7. Conduct a full scan of the build environment to ensure no persistent unauthorized scripts were deployed via existing vulnerabilities by end-of-week.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-55698	Insecure Lockfile Execution in pn...	8.8	High	89/100	CWE-345
CVE-2026-49340	Arbitrary File Write in Gonic Pla...	8.1	High	83/100	CWE-22
CVE-2026-55697	Insecure Engine Selection in pnpm	7.5	High	78/100	CWE-78
CVE-2026-55487	Manifest Spoofing for Lifecycle E...	7.5	High	78/100	CWE-346
CVE-2026-55700	Path Traversal in pnpm Stage Down...	7.1	High	74/100	CWE-22
CVE-2026-49338	IDOR in Subsonic API Playlist Man...	7.1	High	74/100	CWE-285
CVE-2026-49339	Playlist Path Traversal in Gonic ...	7.1	High	74/100	CWE-22
CVE-2026-55699	Unintended Directory Deletion in ...	6.5	Medium	69/100	CWE-22
CVE-2026-53522	DoS via WebSocket Resource Exhaus...	6.5	Medium	69/100	CWE-770
CVE-2026-53523	Host Header Injection in Nezha Mo...	6.8	Medium	61/100	CWE-601
CVE-2026-55180	Environment Secret Leak in pnpm R...	6.5	Medium	59/100	CWE-200
CVE-2026-53465	Heap Buffer Overwrite in ImageMag...	6.2	Medium	56/100	CWE-122
CVE-2026-54243	CSV Formula Injection in Statamic...	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	Memory Leak in ImageMagick Option...	4.0	Medium	46/100	CWE-401
CVE-2026-54242	SSRF via Glide DNS Rebinding	4.9	Medium	44/100	CWE-367
CVE-2026-54244	Improper Authorization in Statami...	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-55698

Finding: Insecure Lockfile Execution in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1204, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm fails to properly validate the integrity of project env lockfiles, allowing them to short-circuit the standard package manager resolution process. Attackers can force the execution of arbitrary bytes defined within the lockfile, potentially leading to remote code execution.

Proof of Concept (PoC):

An attacker distributes a project repository containing a modified lockfile. When a user runs pnpm install, the malicious bytes in the lockfile are processed and executed, granting the attacker control over the user's execution environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

Finding: Arbitrary File Write in Gonic Playlist Creation

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Gonic allows authenticated users to write M3U playlist content to arbitrary locations on the host filesystem via the createPlaylist functionality. This leads to potential command execution or system file corruption.

Proof of Concept (PoC):

An authenticated attacker submits a createPlaylist request with a target file path outside the intended directory. The application saves the provided M3U data to that location, facilitating unauthorized file modification on the host.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-55697

Finding: Insecure Engine Selection in pnpm

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-78

MITRE ATT&CK: T1204, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm permits repository-controlled configDependencies to select a paquet native install engine, allowing for arbitrary code execution in the context of the installation process.

Proof of Concept (PoC):

An attacker creates a malicious repository that specifies a compromised native engine in its configuration. When a user runs pnpm, the tool executes the attacker-defined engine, providing code execution on the user's system.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

Finding: Manifest Spoofing for Lifecycle Execution in pnpm

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-346

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm is vulnerable to manifest identity spoofing, which satisfies build-time checks and allows unauthorized lifecycle scripts to execute on the victim's host.

Proof of Concept (PoC):

An attacker publishes a package with a spoofed manifest that appears legitimate but includes malicious installation lifecycle hooks. When pnpm installs the package, the tool executes the hooks under the user's account.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-55700

Finding: Path Traversal in pnpm Stage Download

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The pnpm package manager fails to properly sanitize manifest names during the stage download process. An attacker can craft a malicious package manifest to write files outside of the intended destination directory, leading to arbitrary file overwrite on the host system.

Proof of Concept (PoC):

An attacker creates a malicious package with a manifest containing directory traversal sequences in its name attribute. Upon installation via pnpm, the tool processes the manifest and extracts files to sensitive host locations, enabling the attacker to overwrite configuration files or binaries.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: IDOR in Subsonic API Playlist Management

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Subsonic API suffers from an Insecure Direct Object Reference (IDOR) vulnerability where authenticated users can access or delete playlists belonging to other users. This compromise affects data privacy and user content management within the platform.

Proof of Concept (PoC):

An authenticated attacker modifies the ID parameter in an API request targeting a playlist endpoint. The server fails to verify if the requester owns the requested resource, allowing the attacker to read or delete content belonging to other users.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Playlist Path Traversal in Gonic API

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Gonic is vulnerable to path traversal within the playlist ID handling logic. Attackers can bypass ownership checks to read or delete arbitrary playlists across the entire user base.

Proof of Concept (PoC):

An attacker sends a request to the playlist API containing traversal characters in the ID field. The backend fails to sanitize the path, allowing the attacker to reference and manipulate any user's playlist file.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-55699

Finding: Unintended Directory Deletion in pnpm

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22

MITRE ATT&CK: T1485

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

A vulnerability in pnpm's global removal process causes it to delete the PNPM_HOME directory when encountering certain reserved binary names. This leads to a denial of service and loss of all globally installed packages.

Proof of Concept (PoC):

A local attacker invokes a global remove command on a package with a specific reserved bin name. The pnpm engine interprets the instruction improperly, resulting in the recursive deletion of the directory containing globally installed packages.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-53522

Finding: DoS via WebSocket Resource Exhaustion

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring contains an issue where WebSocket streams remain unbounded. An attacker can open multiple concurrent streams to exhaust server resources, leading to a denial of service.

Proof of Concept (PoC):

An attacker initiates a large volume of WebSocket connections to the monitoring service without closing them. The server reaches its connection limit, preventing legitimate monitoring traffic from being processed.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-53523

Finding: Host Header Injection in Nezha Monitoring**CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 61/100 | CWE: CWE-601**

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring is vulnerable to Host Header Injection during OAuth2 redirect URL processing. Attackers can manipulate the host portion of the redirect, potentially redirecting users to malicious domains.

Proof of Concept (PoC):

An attacker sends a crafted request to the OAuth2 login flow with a modified Host header. The application incorrectly builds the redirect URL using this input, redirecting the victim's browser to an attacker-specified domain.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>**CVE-2026-55180****Finding: Environment Secret Leak in pnpm Registry Requests****CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-200**

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

pnpm configuration can be manipulated to cause the expansion of victim environment secrets into registry requests before script execution, leading to unauthorized exposure of sensitive credentials.

Proof of Concept (PoC):

An attacker defines a malicious repository configuration that forces pnpm to include environment variables in outgoing HTTP requests. When the target performs an operation, the secrets are sent to an attacker-controlled server.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>**CVE-2026-53465****Finding: Heap Buffer Overwrite in ImageMagick SF3****CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 56/100 | CWE: CWE-122**

MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	High

Description:

ImageMagick exhibits a heap buffer overflow in the SF3 encoder when processing multi-frame images. An attacker can crash the application or potentially execute arbitrary code by supplying a malformed file.

Proof of Concept (PoC):

A user is tricked into processing a malicious multi-frame SF3 file with ImageMagick. The malformed structure causes a heap-based buffer overwrite, resulting in process instability or execution of attacker-supplied instructions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-54243

Finding: CSV Formula Injection in Statamic Exports

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236

MITRE ATT&CK: T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic form submissions are vulnerable to CSV formula injection. Attackers can inject spreadsheet formulas into user-supplied form fields, which execute when the export file is opened by administrative software.

Proof of Concept (PoC):

An attacker fills out a web form with a malicious formula string. When an administrator downloads the exported CSV file and opens it in Excel, the spreadsheet automatically evaluates the formula, potentially executing external commands or leaking sensitive data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>

CVE-2026-53464

Finding: Memory Leak in ImageMagick Option Parser

CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

A memory leak exists in the ImageMagick wand option parser triggered by invalid arguments. Sustained exploitation can lead to resource exhaustion and application denial of service.

Proof of Concept (PoC):

An attacker repeatedly sends requests with invalid options to a service utilizing the ImageMagick library. Each failure leaks memory, eventually resulting in the application consuming excessive system resources and crashing.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>

CVE-2026-54242**Finding: SSRF via Glide DNS Rebinding**

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic is vulnerable to Server-Side Request Forgery (SSRF) in the Glide image processing component through DNS rebinding. Attackers can bypass firewall restrictions to make requests to internal services.

Proof of Concept (PoC):

An attacker controls a malicious DNS server that responds with a public IP for the initial lookup and a local network IP for subsequent requests. By requesting an image through the vulnerable Glide component, the server is forced to connect to internal resources.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>

CVE-2026-54244**Finding: Improper Authorization in Statamic Live Preview**

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Statamic CMS incorrectly handles permissions for the Live Preview feature, allowing users with only 'view' permissions to submit content typically reserved for users with editing roles.

Proof of Concept (PoC):

An authenticated user with low-level privileges navigates to the Live Preview endpoint. The CMS fails to validate the user's role against the required privilege, allowing the user to push content changes that should be restricted.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>